

CO3-ATI

1. Enumeration of scanme.nmap.org

Objective

This objective is to perform an initial security assessment of scanme.nmap.org using Nmap. The enumeration includes host discovery, TCP port scanning, service detection, OS fingerprinting and default script scanning.

Nmap commands

```
nmap -sn scanme.nmap.org
```

```
nmap -ss -sv scanme.nmap.org
```

```
nmap -O scanme.nmap.org
```

```
nmap -sC scanme.nmap.org
```

Enumeration and Analysis

The identified open ports and services are analyzed to understand the server's attack surface and business purpose.

- HTTP/HTTPS : used for providing web-based services and may be necessary for public access

- Other network services : should be checked to determine whether they are actually required

- Service versions : Help identify outdated software and possible vulnerabilities.

Security Risks

An ~~attacker~~ could use the enumeration information to

1. identify vulnerable or outdated services
2. search for known vulnerabilities in specific service versions
3. target exposed login services with brute-force attacks

Recommendations

- Disable unnecessary public services
- Restrict administrative service using firewalls
- Keep operating systems and services updated
- Use strong authentication and access controls

2. Enumeration of metasploitable 2 - 192.168.56.101

Objective

The objective is to comprehensively enumerate the deliberately vulnerable metasploitable 2 Linux server (192.168.56.101) in an isolated laboratory environment. The assessment identifies open ports, services, service versions and OS information.

Nmap commands

```
nmap -ss -sV 192.168.56.101
```

```
nmap -O 192.168.56.101
```

```
nmap -sC 192.168.56.101
```

Analysis of services

The discovered services can be classified according to their

exposure and functionality.

- High Risk : services that provide direct ~~remote~~ access or have known vulnerabilities
- Medium Risk : services that expose useful information or provide possible attack paths
- Low Risk : services with limited security impact but which should still be reviewed

* service version detection is important because the penetration tester can compare the detected versions with known security weakness

possible Attack Entry points

The enumeration results can help a penetration tester to

1. Identify vulnerable services
2. select suitable attack vectors
3. Investigate outdated service versions
4. Examine remote access and file sharing services
5. prioritize high risk services for further authorized testing.

3. Enumeration of windows workstation 192.168.56.102

objective

The objective is to assess the security posture of the windows workstation 192.168.56.102 before connecting

it to the production network. nmap is used to identify

active ports, network services, file sharing protocols, remote management services and os details

Nmap commands

`nmap -ss -sV 192.168.56.102`

`nmap -O 192.168.56.102`

`nmap -sc 192.168.56.102`

Services to check

File sharing : SMB services may allow access to shared files and resources

Remote management : services such as RDP or other management services can increase exposure

Network services : unnecessary open ports can provide additional entry points

OS information : Helps identify the windows version and possible security weakness.

Security Analysis

The principle of least privilege requires only necessary services to remain active.

Hardening measures

1. Disable unnecessary services and ports
2. Restrict SMB and remote management access controls
3. Apply windows security updates regularly

4. Enable firewall rules to allow only required connections
 5. monitor login attempts and suspicious network activity
4. Enumeration of OWASP juice shop server 192.168.56.103

Objective

The objective is to understand the network exposure of the OWASP juice shop server at 192.168.56.103 before conducting a penetration test. The assessment includes host discovery, port scanning and web service identification.

Nmap commands

```
nmap -sn 192.168.56.103
```

```
nmap -ss -sv 192.168.56.103
```

```
nmap -O 192.168.56.103
```

```
nmap -sc 192.168.56.103
```

Analysis of Discovered services

- web service : supports access to the juice shop web application
- HTTP | HTTPS : provides communication between users and the web application
- Administrative services : if exposed, they may increase the server's attack surface
- supporting services : should be checked to ensure that only required services accessible

Recommendations

1. Expose only necessary web services
2. Restrict administrative interfaces to authorized users
3. Keep the web server and supporting software updated
4. use firewall rules to reduce unnecessary exposure
5. monitor web and network activity
6. regularly perform authorized penetration testing

5. Enumeration of network Gateway 192.168.56.1

objective

The objective is to examine the network gateway 192.168.56.1 which acts as the main access point between the internal laboratory network and external networks. The assessment focuses on identifying exposed management services and unnecessary network services.

Nmap commands

```
nmap -ss -sV 192.168.56.1
```

```
nmap -O 192.168.56.1
```

```
nmap -sc 192.168.56.1
```

services to identify

The enumeration should check for

- SSH - Remote administration service

- Telnet - Remote administration, but insecure because communication may be unencrypted
- SNMP - used for network monitoring and management
- HTTP - web based management interface
- HTTPS - secure web based management interface

Security Implications

Exposed management services can increase the attack surface of gateway

1. Weak SSH credentials may allow unauthorized access

2. Telnet can expose sensitive information because of insecure communication

3. Misconfigured SNMP may reveal network and device information

4. Exposed HTTP/HTTPS administration pages may be targeted for unauthorized login

Security Logins & Controls

- Disable unnecessary management services
- Replace Telnet with secure SSH
- Restrict management access to trusted administration
- Use strong passwords and multi factor authentication where supported.